

How it's built

A map of SecureGate's files. You don't need to read code to change its behavior: the last table says which file to edit.

Folders

policy.yaml	the rules that decide block / warn / ignore
.gitleaks.toml	which key shapes Gitleaks looks for
.trufflehog.yaml	TruffleHog's extra detectors (the ACME Pay token)
rules/securegate-risky.yaml	SecureGate's own Semgrep rules: risky handling of secrets
.pre-commit-config.yaml	the laptop gate (installed with make hooks)
.github/workflows/secret-gate.yaml	the merge gate: the check on every pull request
action.yaml	the same merge gate as a GitHub Action, for any repository
.github/CODEOWNERS	who reviews changes to the gate and its rules
Makefile	short commands: make setup, make test, make demo, ...
pyproject.toml	the package: its name, its command and its pinned
packages	
constraints.txt	the exact version of every package it installs, as tested
tested	
Start SecureGate.cmd	double-click: open SecureGate's menu
src/securegate/	the program
tools/	helpers for the gates and the docs
tests/	automatic checks that prove the program works
docs/	these pages

Modules

A **module** is one Python file with one job. When you run a scan, they work in this order:

Module	Job
cli.py	Reads your command (<code>securegate scan ...</code>), runs it, and returns the exit code.
scanners/gitleaks.py	Runs Gitleaks, reads its report from a temporary folder, then deletes the folder.
scanners/trufflehog.py	With <code>--scanners all</code> : runs TruffleHog over the Git history. It can ask the provider whether a key still works.
scanners/changes.py	Copies the code Semgrep and Bandit read into a private folder: in a range scan, the files the range changed, as they are at its end.
scanners/semgrep.py	Runs Semgrep with p/secrets and SecureGate's own rules on that copy. If it fails, the scan goes on and says Semgrep did not run.
scanners/bandit.py	Runs Bandit's password checks (B105, B106, B107) on the Python files of that copy. Optional, like Semgrep.
scanners/versions.py	The versions of TruffleHog, Semgrep and Bandit, for <code>securegate version</code> and the menu.

Module	Job
<code>pipeline.py</code>	The only place raw secrets pass through. It turns each one into a masked finding, then merges findings.
<code>merge.py</code>	Turns findings of the same secret or line into one, keeping the strongest decision and every scanner that found it.
<code>entropy.py</code>	Measures how random a value looks.
<code>policy.py</code>	Reads <code>policy.yaml</code> and decides block, warn or ignore.
<code>confidence.py</code>	Scores from 0 to 1 how sure we are that a finding is a real secret.
<code>mask.py</code>	Hides the value and makes its fingerprint.
<code>finding.py</code>	The finding record. It can only hold a masked value.
<code>report.py</code>	Prints the table, the "why and fix" lines for blocked findings, and writes <code>findings.json</code> .
<code>outputs/</code>	The reports besides <code>findings.json</code> : the pull request comment and the job summary (one template, <code>outputs/templates/report.md.j2</code> ; <code>securegate summary</code> prints it), the checklists to rotate a blocked key (<code>outputs/rotation.py</code>) and SARIF for GitHub's Security tab (<code>outputs/sarif.py</code>). All are made from <code>findings.json</code> read back through the dashboard's check that every value is masked.
<code>demo/</code>	Builds the demo repo: <code>catalog.yaml</code> (what to plant), <code>generator.py</code> , <code>scorecard.py</code> . And the demo pull requests: <code>scenarios.py</code> (the five scenes, their files in <code>pr_templates/</code> and what the gate should say) and <code>pull_requests.py</code> (<code>securegate demo-pr</code> , which builds one in a temporary worktree from origin/main and opens it with <code>gh</code> , and <code>demo-cleanup</code>).
<code>github.py</code>	Runs <code>git</code> and <code>gh</code> for the demo pull requests, <code>doctor</code> and <code>ci-report</code> , and finds the GitHub repository behind <code>origin</code> .
<code>doctor.py</code>	<code>securegate doctor</code> : checks the scanners, the policy, the workflow, <code>gh</code> and GitHub's ruleset, and prints PASS, FAIL or SKIP.
<code>ci_report.py</code>	<code>securegate ci-report</code> : finds a <code>secret-gate</code> run (the newest, a given one, or the one for a pull request's newest commit, waiting if asked), downloads its <code>findings.json</code> and checks it before the dashboard opens it.
<code>ui/</code>	The read-only dashboard: <code>app.py</code> (the pages and downloads), <code>report_view.py</code> (reads and checks <code>findings.json</code>), <code>fixes.py</code> ("How to fix"), <code>export.py</code> (the CSV and JSON downloads), <code>server.py</code> (127.0.0.1 only, on a port it never shares), <code>templates/</code> and <code>static/css/</code> (a dark theme, light when printed).
<code>menu/</code>	The menu that <code>Start SecureGate.cmd</code> and <code>make menu</code> open: <code>app.py</code> (the screen and the choices; each choice runs a <code>securegate</code> command and shows it first, choice 3 shows the pull request comment in the terminal, and choice 9 is the merge gate screen: the five demo pull requests, their results, the gate's reports, clean-up and <code>doctor</code>), <code>art.py</code> (the padlock and the big letters) and <code>terminal.py</code> (colours, only in a real terminal).
<code>agents/</code>	The AI agents (<code>securegate agents</code>): <code>redact.py</code> (takes every secret out of what is sent), <code>client.py</code> and <code>settings.py</code> (Azure AI Foundry, over Python's own HTTPS), <code>tools.py</code> (the five read-only tools), <code>loop.py</code> (one agent's bounded run), <code>triage.py</code> , <code>fix.py</code> and <code>incident.py</code> (each agent's instructions and checks), <code>sanitize.py</code> and <code>advice.py</code> (what comes back, checked), <code>runner.py</code> (asks them and keeps the advice in the report), <code>setup.py</code> (<code>securegate ai-setup</code>) and <code>fix_pr.py</code> (<code>securegate agent-fix</code> : a fix pull request, the edits made by SecureGate itself).
<code>errors.py</code> , <code>validate.py</code> , <code>programs.py</code>	Helpers: error types, checks for hand-edited files, finding programs safely.

Module	Job
<code>scanners/common.py</code> , <code>scanners/candidate.py</code>	What the scanner adapters share: running a program, reading its flags, the raw finding.

The Finding format

Each entry in `findings.json` is one finding. This real example comes from scanning the demo repo:

Field	Example	Meaning
id	<code>dcc7b5bbfe3c</code>	Short name: the first 12 characters of the fingerprint. The same secret always gets the same id.
rule	<code>stripe-access-token</code>	The scanner rule that matched.
detector	<code>gitleaks</code>	The scanner that found it first.
detectors	<code>gitleaks</code> , <code>trufflehog</code>	Every scanner that found it.
file	<code>scripts/migrate_customers.py</code>	Where, relative to the scanned folder.
line	<code>3</code>	The line where the value starts.
commit	<code>720d024c...</code>	The commit that added it. Empty (null) when only files on disk were scanned.
author	<code>Riya Demo</code>	Who made that commit.
date	<code>2025-06-04T09:00:00Z</code>	When.
masked_value	<code>sk_l****562d</code>	The value with all but 4 + 4 characters hidden.
fingerprint	<code>dcc7b5bb...</code> (64 characters)	Recognizes the same secret again. It cannot be turned back into the secret.
entropy	<code>4.625</code>	How random the value looks (random keys: about 4 to 6).
confidence	<code>0.9</code>	0 to 1: how sure we are that it is a real secret.
validity	<code>not_checked</code>	Is the key live? verified (the provider confirmed it works), unknown (the check failed), unverified (not confirmed) or not_checked . Only TruffleHog checks.
severity	<code>high</code>	critical, high, medium, low or info, from the policy.
decision	<code>block</code>	block, warn or ignore, from the policy.
matched_rule	<code>rule 8: provider-keys</code>	The policy rule that decided, with its number.
reason	<code>provider-keys: A payment, cloud or ...</code>	Which policy rule decided, and why.
remediation	<code>Treat it as leaked. Rotate ...</code>	What to do next.

The file also has a summary at the top: status (pass, fail or error), exit code, Gitleaks version, which scanners ran and counts per decision. After an error it has no findings list at all, so nobody can mistake a failed scan for a clean one.

Exit codes

Code	Meaning
0	Pass. Nothing to block (there may be warnings).
1	At least one finding is "block".

Code	Meaning
2	SecureGate could not do its job: Gitleaks missing, a broken <code>policy.yaml</code> , an unreadable report. It never says "pass" when something went wrong.

Where to change what

I want to...	Change this
block, warn or ignore a kind of finding	<code>policy.yaml</code> : add or move a rule
treat a folder differently	<code>policy.yaml</code> : <code>path_matches</code>
ignore a known fake value	<code>policy.yaml</code> : <code>value_matches</code> in the <code>placeholders</code> rule
change the "why" or "fix" line shown for a blocked finding	<code>policy.yaml</code> : <code>reason</code> and <code>remediation</code> of that rule
detect a new kind of key	<code>.gitleaks.toml</code> : add a <code>[[rules]]</code> entry, like <code>acme-pay-token</code> ; for TruffleHog too, <code>.trufflehog.yaml</code>
install TruffleHog, Semgrep and Bandit, or change their versions	<code>make scanners</code> ; the versions are in the <code>env:</code> block at the top of <code>.github/workflows/secret-gate.yaml</code>
change how findings of the same line are merged	<code>src/securegate/merge.py</code>
change the pull request comment or the job summary	<code>src/securegate/outputs/templates/report.md.j2</code>
change the steps to rotate a blocked key	<code>src/securegate/outputs/rotation.py</code>
change the SARIF file for GitHub's Security tab	<code>src/securegate/outputs/sarif.py</code>
catch another risky way of handling a secret	<code>rules/securegate-risky.yaml</code> (and its sample in <code>tests/test_code_scanners_real.py</code>)
plant a new secret or decoy in the demo	<code>src/securegate/demo/catalog.yaml</code> (see Testing (testing.pdf))
change how values are masked	<code>src/securegate/mask.py</code>
change the table or <code>findings.json</code>	<code>src/securegate/report.py</code>
change the confidence score	<code>src/securegate/confidence.py</code>
change the dashboard's colours, fonts or spacing, on screen or on paper	<code>src/securegate/ui/static/css/tokens.css</code> (see Dashboard (ui.pdf))
change what a dashboard page shows	<code>src/securegate/ui/templates/</code>
change the columns of the CSV download, or the JSON download	<code>src/securegate/ui/export.py</code>
change the "How to fix" advice	<code>src/securegate/ui/fixes.py</code>
change what the check on pull requests does	<code>.github/workflows/secret-gate.yaml</code> (see The two gates (merge-gate.pdf))

I want to...	Change this
change what a demo pull request contains, or what the gate should say about it	<code>src/securegate/demo/pr_templates/</code> and <code>src/securegate/demo/scenarios.py</code> (<code>tests/test_demo_kit.py</code> checks each scene against the policy)
change what securegate doctor checks	<code>src/securegate/doctor.py</code>
change who reviews changes to the gate	<code>.github/CODEOWNERS</code>
change the check before each commit	<code>.pre-commit-config.yaml</code> and <code>tools/precommit_hook.py</code>
change the menu's choices, or what they run	<code>src/securegate/menu/app.py</code> (<code>tests/test_menu.py</code> checks that every command it runs exists, and that choice 2 runs what <code>make scan-demo-all</code> runs)
change the art on the menu's first screen, or its colours	<code>src/securegate/menu/art.py</code>
change what double-clicking Start SecureGate.cmd does before the menu opens	<code>Start SecureGate.cmd</code> (a Windows batch file; <code>tests/test_launcher.py</code> checks the commands it runs)
change what an AI agent is told, or what it must answer	<code>src/securegate/agents/triage.py</code> , <code>fix.py</code> or <code>incident.py</code> (SYSTEM and SCHEMA)
change what is taken out of code before an AI agent sees it	<code>src/securegate/agents/redact.py</code> (<code>tests/test_agents_safety.py</code> proves nothing planted gets through)
change the AI model or how Azure is called	the deployment in <code>securegate ai-setup</code> , or <code>src/securegate/agents/client.py</code>
change how the AI advice is shown	<code>src/securegate/outputs/templates/report.md.j2</code> (the comment), <code>src/securegate/ui/templates/advice.html</code> and <code>finding.html</code> (the dashboard), <code>src/securegate/menu/app.py</code> (choice A)
update the PDF copies of these pages	edit the <code>.md</code> page, then run <code>make docs-pdf</code> (<code>tools/docs_pdf.py</code>)

When you change a behavior, update the matching page in `docs/` in the same commit, and run `make docs-pdf` so its PDF matches. A test fails when a PDF is out of date.